



Agents build
You lead
We secure

Prevent, detect,
manage, and fix
vulnerabilities
continuously.



TEMATICA

Trilema moderno IA, software y seguridad.

Detrás de la cadena de suministro

Juan Restrepo

CTO





Juan Restrepo

CTO

Responsable de apoyar la estrategia de la compañía desde la tecnología, por lo que dirige al equipo de desarrollo de software, garantizando que se cumplan estándares de calidad y seguridad.

[linkedin.com/in/juancrestrepo](https://www.linkedin.com/in/juancrestrepo)

jrestrepo@fluidattacks.com

Es la IA una nueva amenaza?
No lo es.

Cual es la verdadera amenaza?
Cuáles vulnerabilidades remediar?

- 47 Ingenieros
- 3 Head of Engineering
- LATAM bootstrapped PLG product
- SAST, SCA, DAST, CSPM, ASPM, AI, Secrets, API, IDE ext.
- 9 Años: primer commit 2016/07/12
- 1.2 MLOC: PY, TS, TF & Nix (95%)
- No scrum, cero reuniones
- 100% remoto, organico asincrono
- 2.3 despliegues diarios por Dev.
- Trunk Based Development
- Mono Repositorio
- No ambientes permanentes
- 1 Commit = 1 Despliegue

3.6%

Change
Failure Rate

99.7%

Closed
Vulnerabilities

0.94

Apdex

250 LoC

Max. tamaño
MR

3Hrs

Lead Time

100

Security
Score Card

\$300
/mes/dev

AI Driven
Development

+51%

LoC Churn

54%

Commits

```
1 module.exports = leftpad;
2 function leftpad (str, len, ch) {
3   str = String(str);
4   var i = -1;
5   if (!ch && ch !== 0) ch = ' ';
6   len = len - str.length;
7   while (++i < len) {
8     str = ch + str;
9   }
10  return str;
11 }
```

**“I think I have the
right of deleting all
my stuff.” Koçulu,
2016**

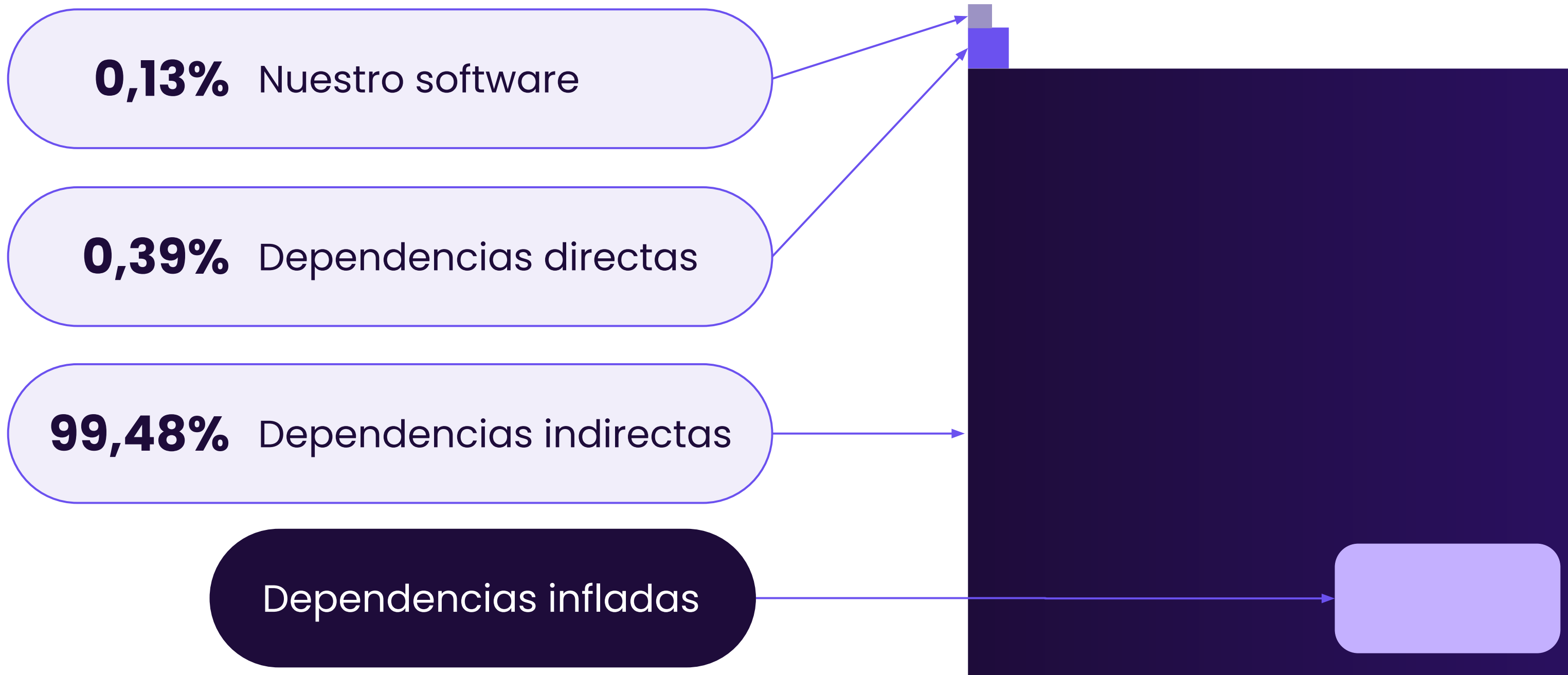
Fuente: <https://qz.com/646467/how-one-programmer-broke-the-internet-by-deleting-a-tiny-piece-of-code>

IA. Nuevo reto de seguridad?

- **LiteLLM:** Envenenaron el gateway de IA con 95M descargas mensuales, exponiendo credenciales de más de 100 proveedores LLM.
- **Telnyx SDK:** Comprometieron el SDK oficial de Telnyx en PyPI ocultando el malware dentro de un archivo WAV.
- **Axios:** Fue comprometido introduciendo una dependencia maliciosa para robar credenciales de entorno.
- **GlassWorm:** Comprometió simultáneamente cientos de paquetes npm, repositorios GitHub y extensiones de VSCode, con el objetivo de robar credenciales.
- **TrapDoor:** Distribuyó mas de 34 paquetes maliciosos a traves de 384 versiones afectando de forma simultanea NPM, PyPi y Crates.
- **Github:** Filtración de +3.800 repositorios por una extensión maliciosa de VS Code.

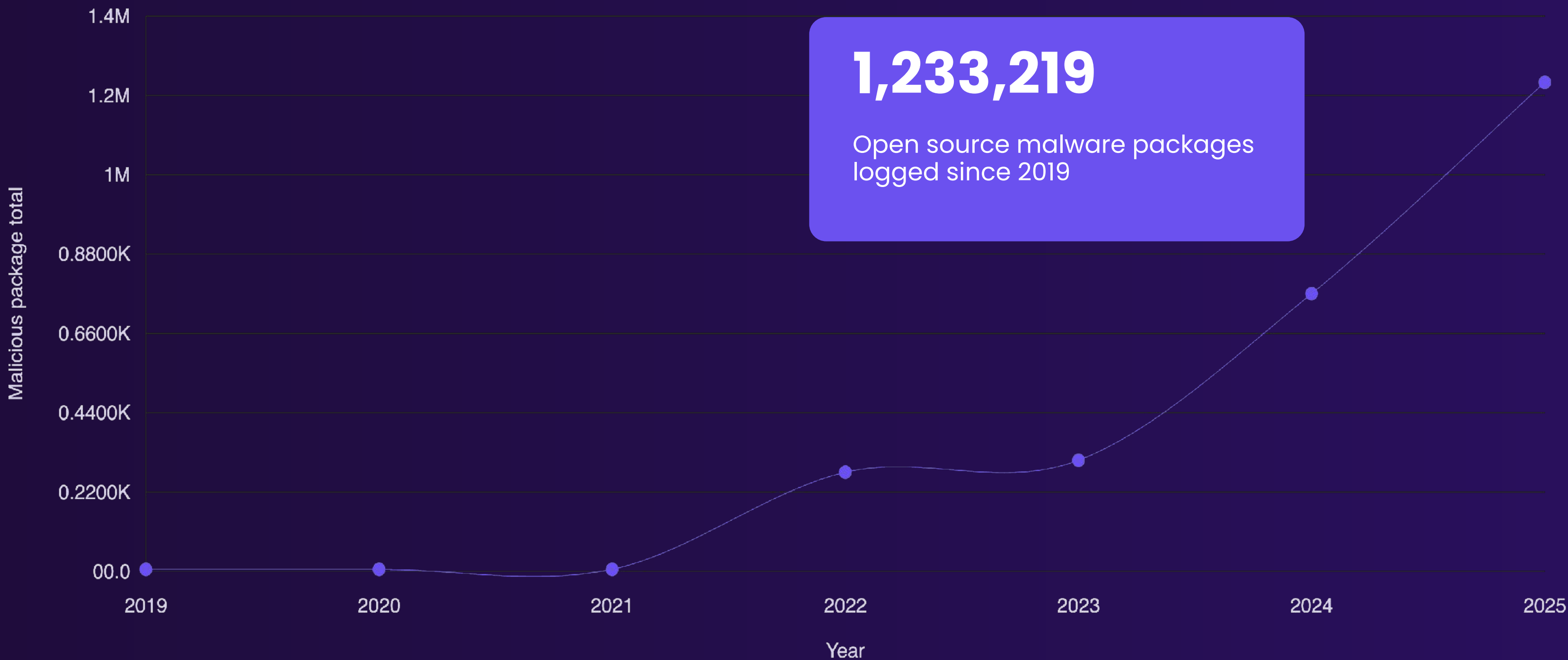


Proporción de código de terceros



*Medido en número de dependencias. Phylum, 2023.

Annual open source malware growth



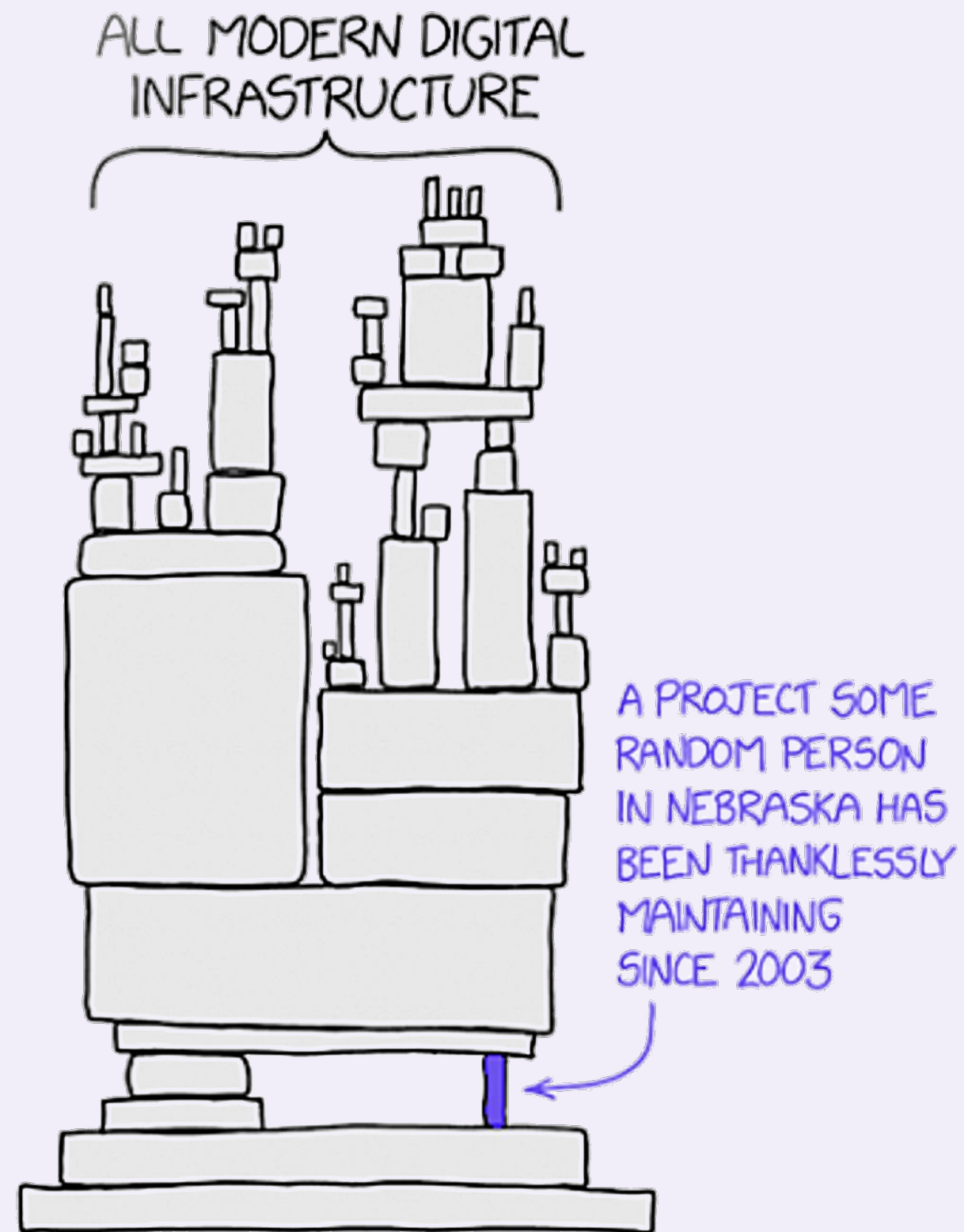
Adopción de actualizaciones



Component	Downloads 2025
commons-compress	46.32%
commons-lang	99.88%
snappy	99.58%
jdom2	57.73%
Log4j	13%

Descargas de versiones vulnerables en componentes con versiones seguras disponibles.

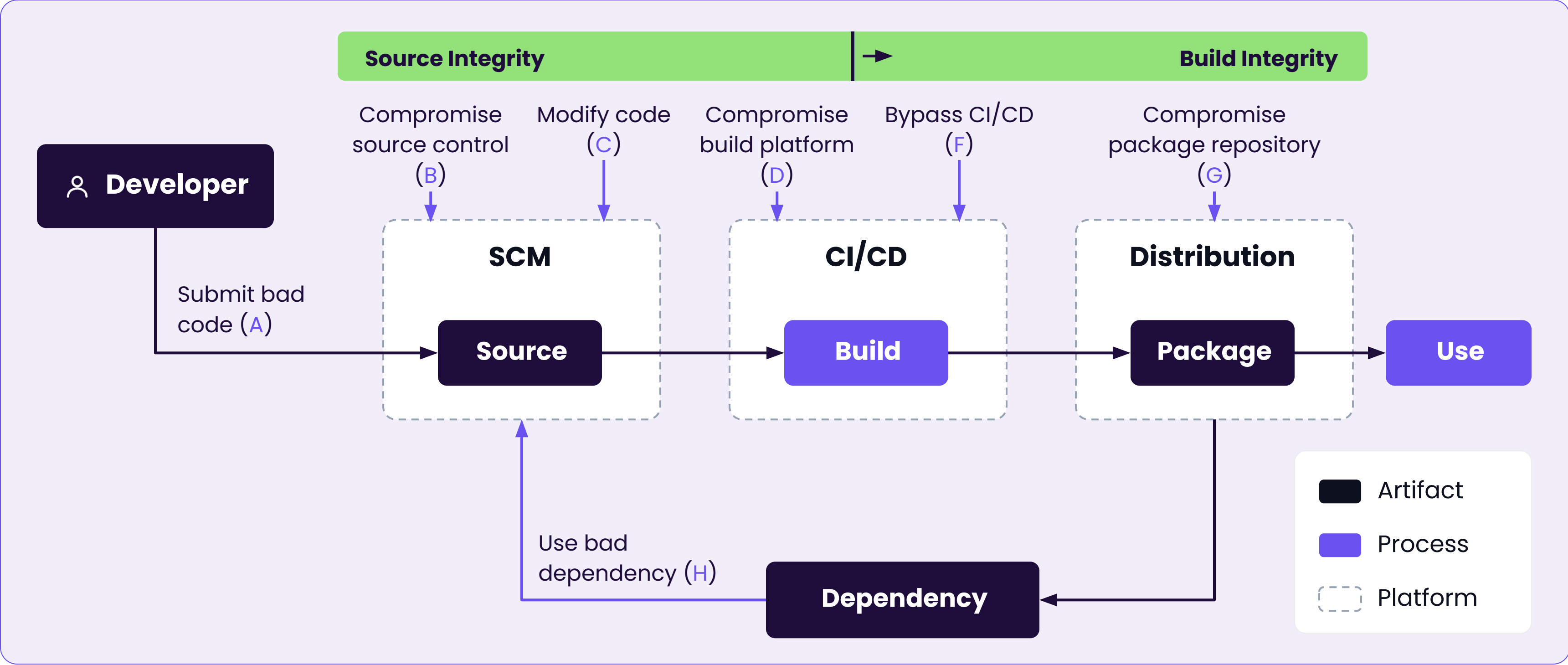
Fuente: <https://www.sonatype.com/state-of-the-software-supply-chain>



¿Simplemente
un mal chiste?

Software Supply Chain Security

Source Integrity vs. Build Integrity



Transparencia obligatoria

- 01 SBOM (SPDX – ISO/IEC 5962:2021; CycloneDX)
- 02 SBOM + VEX
- 03 AIBOM
- 04 EU Cyber Resilience Act
- 05 Cyber labeling (Singapur, Finlandia, Alemania)
- 06 SLSA
- 07 S2C2F
- 08 UK CSRB



La "ñapa": Pilares de nuestro ASDLC



250 LoC

Tamaño Pull Request



Trunk Based Dev

Directo a Main (No intermedio).



Multiples Ramas

Un solo ingeniero.



Romper el Build

Pipeline estricto y determinístico

- Iteración corta y constante.
- Zero Trust SDLC
- secure by ~~compliance~~ default
- Seguridad como atributo no como etapa en el CI.
- Remediación proactiva.

Acceptance Rate & Approved MRs — por mes

MRS ABR 2026

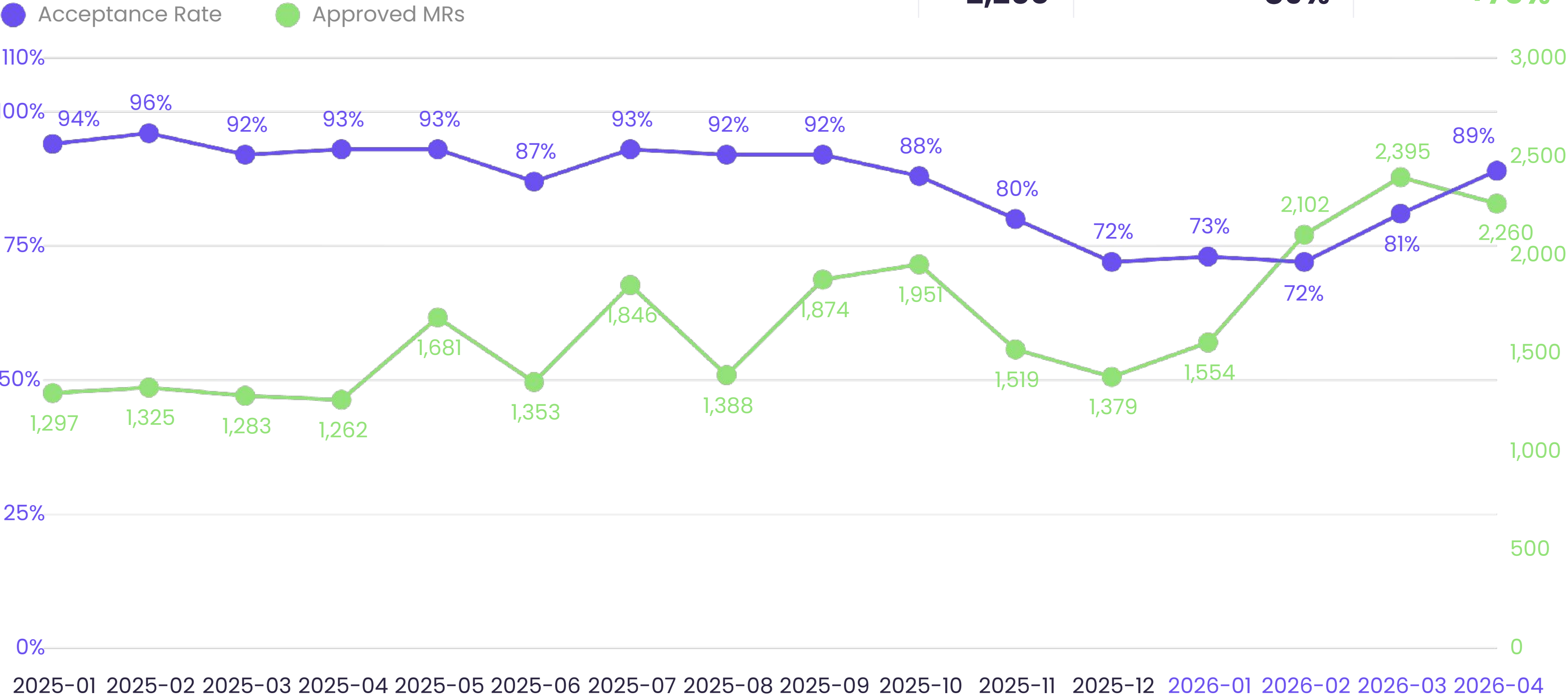
2,260

ACEPTACIÓN ABR 2026

89%

MRS VS ENE 2025

+75%



Fuente: Fluid Attacks · datos de code review enero 2025 – abril 2026

MTTR por mes — tiempo medio de resolución

MEDIANA 2025

MEDIANA 2026

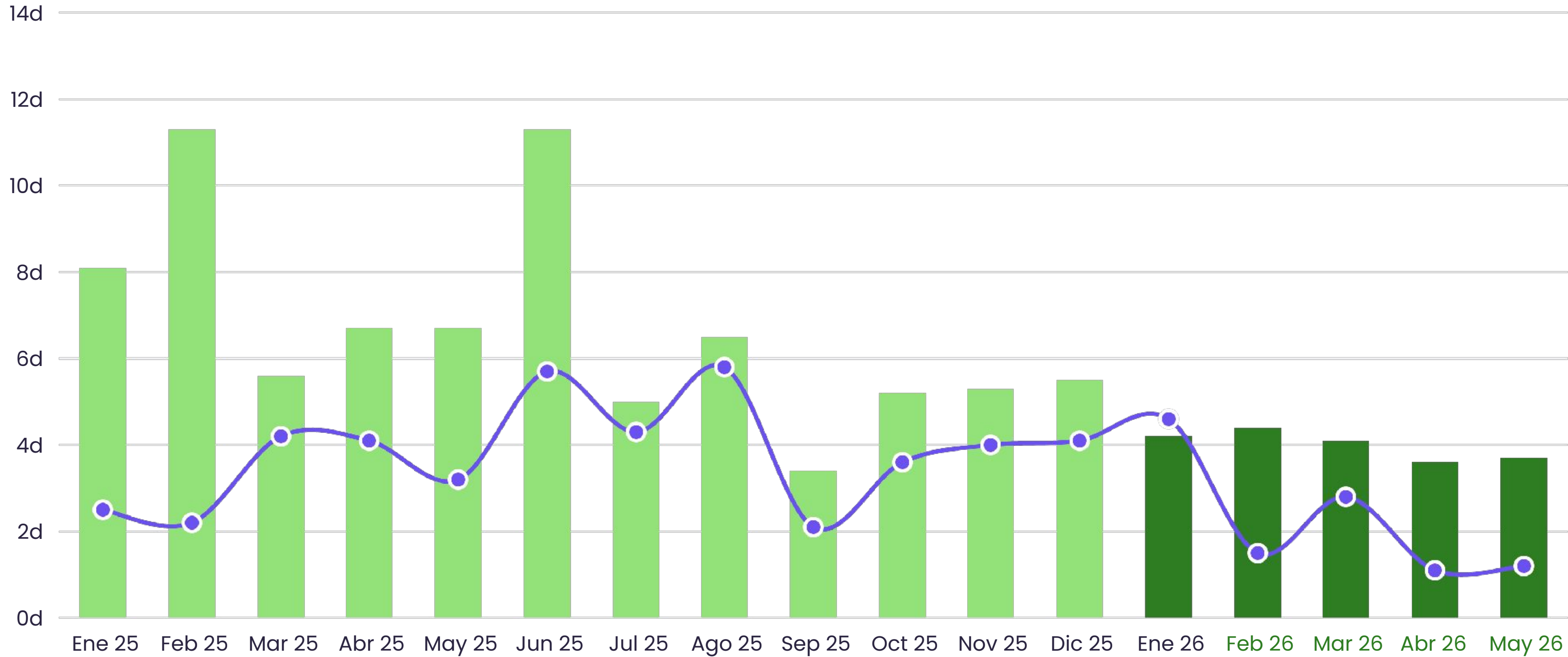
MEJORA

3.7 d

1.5 d

-59%

Media (días) Mediana (días) ← 2025 · adopción IA · 2026 →



Fuente: fluidattacks/universe · work items exportados 2026-05-25 · n=683 issues cerrados

Gracias

Conectemos

Web

<https://fluidattacks.com/>

Email

info@fluidattacks.com

Ubicación

95 3rd Street, 2nd Floor
San Francisco, CA 94103

Teléfonos

+1 415 404 2154

+57 (604) 4442637



<https://go.fluidattacks.tech/trilema-moderno>